

Seguridad Informática



Realizado por:

Joan Ismael Ayala Rodriguez

Kevin Jose Arriaga

Mario Sotillo Buesa

ÍNDICE

1. Conceptualización de la Seguridad	4
1.1. Definición y Alcance	4
1.2. Marco Teórico: La Tríada de la Seguridad (Modelo AIC)	4
1.3. Diferenciación de Conceptos Operativos	4
1.4. Objetivos Primordiales	5
2. El Sistema Informático	5
2.2. Software	5
2.3. Humanware	6
2.4. Información (Dataware)	6
2.5. Servicios (Dimensión Funcional)	6
3. Sistema Seguro frente a Sistema Fiable	7
3.1. El Concepto de Fiabilidad (Reliability)	7
3.2. El Concepto de Seguridad (Security)	7
3.3. Divergencias en la Gestión de Fallos	7
4. Características de un Sistema Seguro	8
4.1. Confidencialidad	8
4.2. Integridad	8
4.3. Disponibilidad	8
4.4. No Repudio	9
4.5. Autenticación	9
4.6. Fiabilidad	9
5.1. Intercepción	10
5.2. Modificación	10
5.3. Interrupción	10
5.4. Fabricación	10
6. Seguridad Activa frente a Seguridad Pasiva	11
6.1. Seguridad Activa	11
6.2. Seguridad Pasiva: La Estrategia de Resiliencia	11
6.3. Sinergia entre Modelos	12
7. Medidas de Seguridad	12
7.1. Prevención	12
7.2. Detección	12
7.3. Restauración	13
7.4. Análisis Forense	13
8. Clasificación de las Amenazas	13
8.1. Amenazas Físicas	14
8.2. Amenazas Lógicas	14
8.3. Amenazas Humanas	14
9. Factores de Autenticación	15
9.1. Factor de Inherencia (“Eres”)	15
9.2. Factor de Conocimiento (“Conoces”)	15

9.3. Factor de Posesión ("Tienes")	16
10. Mecanismos de Seguridad	16
10.1. Medidas de acceso físico	16
10.2. Medidas de acceso lógico: contraseñas, etc...	16
10.3. Protección de la información: permisos, cifrado, información redundante, etc...	17
10.4. Respaldo de la información: copia de seguridad, clonación, congelación	17
10.5. Almacenamiento seguro: RAID, almacenamiento compartido, NAS, nube, etc...	18
10.6. Restauración: herramientas de rescate del sistema	18
10.7. Configuración y arquitectura de red	19
10.8. Encriptación, protocolos seguros y certificados	19
10.9. Cortafuegos (Firewall)	19
10.10. Monitorización y análisis de red	20
10.11. Acceso privado: proxy, vpn	20
11. Criptografía	21
11.1. Definición	21
11.2. Usos	21
11.3. Cifrados antiguos: Escítala, César, Blaise de Vigenere, Enigma, etc.	22
11.4. Tipos de cifrado	22
11.4.1. Simétrico (DES, 3DES, AES, RC5, Blowfish, IDEA, ...)	22
11.4.2. Asimétrico (DSA, RSA, Diffie-Hellman, ...)	23
11.4.3. Cifradores de flujo (WEP, WPA)	23
11.4.4. Hash/resumen/digest (MD5, SHA1, SHA256, CRC, ...)	24
11.5. Protocolos seguros (PGP/GPG, SSL, SSH, DSS, TLS, ...)	24
11.6. Ataques	25
11.6.1. Clave (fuerza bruta, diccionario, ingeniería social, keyloggers, ...)	25
11.6.2. Cifrado (estadística, criptoanálisis)	26
12. Ingeniería Social	26
12.1. Definición y Principios Fundamentales	26
12.2. Fases de un Ataque de Ingeniería Social	27
12.3. Técnicas Comunes de Ingeniería Social	27
12.4. Medidas de Mitigación	28
13. Normativa de Seguridad	28
13.1. Ámbito Europeo (Unión Europea)	28
13.2. Ámbito Nacional (España)	28
13.3. Certificaciones y Estándares Internacionales	29
13.4. Ética y Responsabilidad Legal	29
Bibliografía	30

1. Conceptualización de la Seguridad

1.1. Definición y Alcance

La seguridad informática, enmarcada actualmente bajo el término más amplio de ciberseguridad, se define como la disciplina encargada de diseñar y aplicar normas, procedimientos y tecnologías destinados a salvaguardar los activos de información. A diferencia de otras disciplinas técnicas, la seguridad no es un estado estático, sino un proceso cíclico y preventivo que busca mitigar los riesgos derivados del tratamiento de datos en sistemas interconectados.

Desde una perspectiva técnica, la seguridad informática implica la protección integral de tres capas críticas de la infraestructura:

- **Capa Física:** Se refiere a la protección del hardware, las instalaciones y los perímetros frente a daños o accesos no autorizados.
- **Capa Lógica:** Centrada en la salvaguarda del software, los protocolos de comunicación y los sistemas operativos.
- **Capa Humana:** Enfocada en la gestión del factor humano mediante políticas de concienciación, capacitación y ética profesional.

1.2. Marco Teórico: La Tríada de la Seguridad (Modelo AIC)

El pilar fundamental sobre el que se construye cualquier estrategia de seguridad es el modelo de la Tríada AIC (o CIA, por sus siglas en inglés). Este estándar internacional define los tres servicios esenciales que deben garantizarse:

- **Confidencialidad:** Propiedad que asegura que la información no se ponga a disposición ni se revele a individuos, entidades o procesos no autorizados. Su vulneración resulta en la filtración de datos sensibles.
- **Integridad:** Garantía de la exactitud y completitud de la información. Los sistemas de seguridad deben asegurar que los datos no sean alterados de forma no autorizada durante su almacenamiento o tránsito.
- **Disponibilidad:** Aseguramiento de que los sistemas, aplicaciones y datos sean accesibles y utilizables en el momento exacto en que los usuarios autorizados lo requieran.



1.3. Diferenciación de Conceptos Operativos

Para un estudio riguroso de la seguridad, es imperativo establecer la distinción técnica entre los componentes que definen el riesgo. En primer lugar, el Activo de Información representa cualquier recurso (dato, servidor o propiedad intelectual) que posea valor para la organización. Sobre este activo puede existir una vulnerabilidad, definida como una debilidad intrínseca en el sistema o diseño que puede ser aprovechada por un agente externo.

Por otro lado, la amenaza constituye la causa potencial de un incidente capaz de dañar el sistema (como malware, desastres naturales o ingeniería social). Finalmente, el impacto se define como la medida del daño o pérdida resultante en caso de que dicha amenaza logre materializarse explotando la vulnerabilidad del activo.

1.4. Objetivos Primordiales

El objetivo último de la seguridad informática no es la eliminación total del riesgo (objetivo técnicamente inalcanzable en entornos digitales), sino su gestión y reducción hasta niveles aceptables para la organización. De este modo, se busca garantizar la continuidad operativa, la protección de los intereses institucionales y el estricto cumplimiento del marco legal vigente.

2. El Sistema Informático

En el marco de la seguridad informática, un sistema informático se define como un conjunto complejo de elementos interrelacionados que interactúan entre sí para procesar, almacenar y distribuir información. Para fines de análisis de riesgos, este sistema se descompone en cinco dimensiones críticas:

2.1. Hardware

El hardware constituye la base material del sistema. Incluye todos los componentes físicos y tangibles que permiten el funcionamiento del entorno digital.



- **Elementos:** Servidores, estaciones de trabajo, dispositivos de red (routers, switches), soportes de almacenamiento y periféricos.
- **Perspectiva de Seguridad:** La protección se centra en la seguridad física, el control de acceso a los centros de datos, la redundancia de equipos y la protección contra fallos eléctricos o desastres naturales.

2.2. Software

El software comprende el conjunto de instrucciones, programas y reglas informáticas que permiten al hardware realizar tareas específicas.

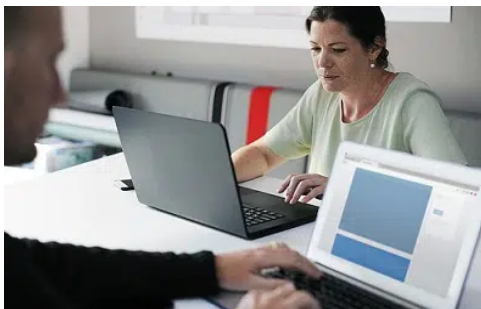
Categorías:

- **Software de Sistema:** Sistemas operativos (Windows, Linux, macOS) y firmware.
- **Software de Aplicación:** Herramientas de productividad, bases de datos y software empresarial.
- **Perspectiva de Seguridad:** Se enfoca en la gestión de parches, el desarrollo de código seguro, el control de privilegios y la protección contra software malicioso (malware).



2.3. Humanware

El humanware se refiere al factor humano involucrado en el diseño, operación y uso de los sistemas. Es considerado el "eslabón más débil" pero también la primera línea de defensa en la cadena de seguridad.

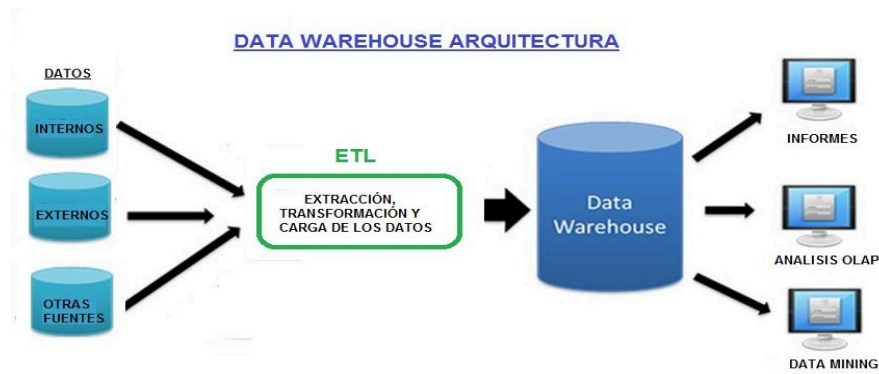


- **Roles:** Administradores de sistemas, desarrolladores, usuarios finales y personal de soporte.
- **Perspectiva de Seguridad:** Se aborda mediante la ingeniería social, políticas de uso aceptable, capacitación en ciber higiene y la concienciación sobre riesgos.

2.4. Información (Dataware)

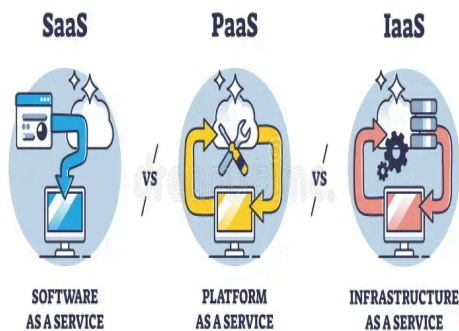
La información es el activo más valioso de cualquier sistema informático. Representa los datos procesados que poseen significado y utilidad para la toma de decisiones.

- **Estado de los Datos:**
 - **En reposo (at rest):** Datos almacenados en discos o bases de datos.
 - **En tránsito (in transit):** Datos moviéndose a través de la red.
 - **En uso (in use):** Datos siendo procesados en la memoria RAM o CPU.
- **Perspectiva de Seguridad:** Implementación de cifrado, control de integridad de datos y cumplimiento de normativas de protección de datos (como el RGPD).



2.5. Servicios (Dimensión Funcional)

Los servicios son las funciones o capacidades específicas que el sistema ofrece a sus usuarios o a otros sistemas a través de protocolos de comunicación.



- **Ejemplos:** Servicios de correo electrónico, alojamiento web, servicios en la nube (SaaS, PaaS), y servicios de autenticación (Active Directory).
- **Perspectiva de Seguridad:** Garantizar la Disponibilidad de estos servicios, evitar ataques de Denegación de Servicio (DoS) y asegurar que las interfaces de programación de aplicaciones (API) sean robustas.

3. Sistema Seguro frente a Sistema Fiable

3.1. El Concepto de Fiabilidad (Reliability)

La fiabilidad se define como la capacidad de un sistema para realizar las funciones requeridas bajo condiciones establecidas durante un tiempo determinado. En términos de investigación, la fiabilidad está intrínsecamente ligada a la ausencia de fallos accidentales.

Un sistema fiable es aquel que garantiza la continuidad del servicio frente a errores de hardware, fallos en el suministro eléctrico o defectos de programación no intencionados. El estudio de la fiabilidad se basa en modelos estadísticos y probabilísticos, donde se analizan las tasas de error de los componentes para prever su vida útil. El objetivo primordial aquí es la estabilidad operativa: que el sistema haga exactamente aquello para lo que fue diseñado, sin interrupciones inesperadas.

3.2. El Concepto de Seguridad (Security)

La seguridad se enfoca en la capacidad del sistema para resistir acciones deliberadas y malintencionadas que buscan comprometer sus recursos. Mientras que la fiabilidad combate el azar y el desgaste, la seguridad combate a un adversario inteligente.

Un sistema seguro es aquel diseñado para proteger la tríada de la información (confidencialidad, integridad y disponibilidad) frente a intrusiones, sabotajes o exfiltración de datos. En este escenario, el fallo no ocurre por una degradación natural del componente, sino por una manipulación externa que explota una debilidad (vulnerabilidad) para forzar al sistema a comportarse de una manera no prevista por sus creadores.

3.3. Divergencias en la Gestión de Fallos

La distinción académica más relevante reside en la naturaleza del evento que provoca la caída del sistema:

En la fiabilidad, los eventos son independientes y accidentales. Si un servidor falla por un error en su memoria RAM, se considera un problema de fiabilidad. Las soluciones típicas incluyen la redundancia de hardware y el mantenimiento preventivo.

En la seguridad, los eventos son causales y hostiles. Si el servidor deja de responder porque un atacante ha saturado sus recursos mediante un ataque de denegación de servicio (DDoS), nos enfrentamos a un problema de seguridad. Las soluciones en este ámbito implican sistemas de detección de intrusos, cortafuegos y políticas de control de acceso.

4. Características de un Sistema Seguro

Para que un sistema sea considerado robusto y protegido desde una perspectiva de investigación, debe cumplir con una serie de propiedades fundamentales. Estas características conforman el marco de confianza sobre el cual se operan los datos y se ejecutan los procesos.

4.1. Confidencialidad

La confidencialidad es la propiedad que asegura que la información no sea divulgada a personas, entidades o procesos no autorizados. En términos de investigación, se considera la prevención de la fuga de datos. Su implementación técnica se basa primordialmente en el cifrado de datos (criptografía) y en el establecimiento de controles de acceso estrictos, garantizando que el mensaje solo sea comprensible para el receptor legítimo.

4.2. Integridad

Esta característica garantiza que la información se mantenga exacta, completa y no haya sido alterada durante su almacenamiento o transporte, ya sea por accidente o de forma malintencionada. Para validar la integridad, se utilizan mecanismos como las funciones hash y las firmas digitales, que permiten detectar cualquier modificación mínima en el bit de un archivo o mensaje, asegurando que el dato recibido es idéntico al generado originalmente.

4.3. Disponibilidad

La disponibilidad asegura que los usuarios autorizados tengan acceso a la información y a los recursos del sistema siempre que lo requieran. Un sistema seguro debe ser resiliente ante ataques de Denegación de Servicio (DoS) o fallos técnicos. Esto se logra mediante el diseño de arquitecturas redundantes, el mantenimiento de infraestructuras y la aplicación de planes de contingencia que eviten la interrupción del flujo de trabajo.



4.4. No Repudio

El no repudio es la capacidad técnica de garantizar que ninguna de las partes involucradas en una comunicación o transacción pueda negar su participación en la misma. Existen dos vertientes:

- **No repudio en origen:** El emisor no puede negar haber enviado el mensaje.
 - **No repudio en destino:** El receptor no puede negar haber recibido el mensaje.
- Se sustenta legal y técnicamente mediante el uso de certificados digitales y firmas electrónicas avanzadas.

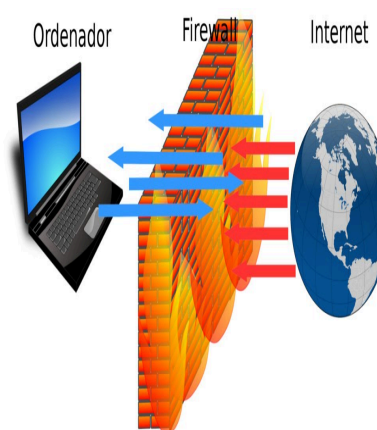
4.5. Autenticación



La autenticación es el proceso de verificación de la identidad de un usuario, dispositivo o sistema que intenta acceder a un recurso. Es el paso previo a la autorización. Se divide generalmente en tres factores de verificación: algo que el usuario sabe (contraseña), algo que el usuario tiene (token físico o digital) y algo que el usuario es (biometría). Un sistema seguro moderno suele exigir la combinación de al menos dos de estos factores (MFA).

4.6. Fiabilidad

Como se analizó previamente, la fiabilidad en un sistema seguro se refiere a la consistencia del comportamiento del sistema y su capacidad de operar sin errores durante periodos prolongados. En el contexto de un sistema seguro, la fiabilidad aporta la certeza de que los mecanismos de protección (como el cortafuegos o el sistema de cifrado) no fallarán por degradación interna, manteniendo la infraestructura estable para que las demás características de seguridad puedan ejercer su función.



5. Categorías de Ataque

En el análisis de riesgos, los ataques se clasifican en función del objetivo que persigue el adversario y el efecto que produce en la relación emisor-receptor. Estas cuatro categorías representan las amenazas fundamentales contra un sistema de información.

5.1. Intercepción

La intercepción es un ataque que vulnera la confidencialidad del sistema. En este escenario, una entidad no autorizada logra acceder a un recurso o a la comunicación entre dos puntos legítimos.

- **Naturaleza:** Se considera un ataque pasivo, ya que el atacante generalmente no altera los datos ni interrumpe el flujo, lo que hace que su detección sea extremadamente difícil.
- **Ejemplos técnicos:** El "sniffing" de paquetes en una red inalámbrica no cifrada, la copia no autorizada de archivos protegidos o la escucha de líneas de comunicación (wiretapping).

5.2. Modificación

Este ataque representa una violación directa de la integridad. En esta categoría, el atacante no solo accede al recurso o mensaje (intercepción), sino que altera su contenido antes de que llegue a su destino final o mientras está almacenado.

- **Naturaleza:** Es un ataque activo que busca engañar al receptor o manipular los procesos del sistema mediante la alteración de datos.
- **Ejemplos técnicos:** La inyección de código malicioso en una base de datos (SQL Injection) para alterar registros financieros, o la modificación de los campos de un paquete de red en tránsito para cambiar la cuenta bancaria de destino.

5.3. Interrupción

La interrupción constituye un ataque contra la disponibilidad del sistema. El objetivo principal es lograr que un recurso del sistema sea destruido o se vuelva inutilizable, impidiendo que los usuarios legítimos accedan a él.

- **Naturaleza:** Es un ataque activo y destructivo. No busca necesariamente robar información, sino sabotear la operatividad.
- **Ejemplos técnicos:** Ataques de Denegación de Servicio (DoS/DDoS) que saturan un servidor web, la destrucción física de un disco duro, o el corte deliberado de un cable de fibra óptica.

5.4. Fabricación

La fabricación es un ataque que atenta contra la autenticidad. En este caso, el atacante inserta objetos o mensajes falsos dentro del sistema, pretendiendo que provienen de una fuente legítima.

- **Naturaleza:** Es un ataque activo basado en la suplantación. Busca confundir al sistema o al usuario para que acepten como verdadera una información falsa.
- **Ejemplos técnicos:** La creación de correos electrónicos falsos que imitan a una entidad bancaria (Phishing), la generación de certificados digitales falsificados o la inserción de registros espurios en una tabla de enrutamiento para redirigir el tráfico.

6. Seguridad Activa frente a Seguridad Pasiva

6.1. Seguridad Activa

La seguridad activa se define como el conjunto de medidas y herramientas que se implementan con el objetivo de evitar que se produzca un incidente de seguridad o, en su defecto, para detectarlo y detenerlo en tiempo real. Su naturaleza es proactiva y se enfoca en reducir la superficie de exposición ante posibles amenazas.

En un entorno de investigación, la seguridad activa se asocia con el concepto de barrera. Entre sus implementaciones más comunes destacan:

- **Gestión de Identidades:** El uso de contraseñas robustas, sistemas biométricos y la autenticación multifactor (MFA).
- **Software de Defensa:** Cortafuegos (firewalls) configurados para filtrar tráfico malicioso, sistemas de detección y prevención de



intrusiones (IDS/IPS) y programas antimalware que analizan el sistema de forma continua.

- **Cifrado de la Información:** La encriptación de datos en tránsito y en reposo para que, en caso de interceptación, la información resulte ilegible.
- **Auditorías y Parches:** El escaneo frecuente de vulnerabilidades y la actualización constante del sistema operativo y las aplicaciones.

6.2. Seguridad Pasiva: La Estrategia de Resiliencia

La seguridad pasiva comprende todas aquellas medidas que se ponen en marcha una vez que el incidente se ha materializado o cuando los controles de la seguridad activa han sido vulnerados. Su finalidad no es evitar el ataque, sino minimizar el impacto del daño, garantizar la continuidad del negocio y restaurar el sistema a su estado original.

La seguridad pasiva asume que la invulnerabilidad absoluta no existe y se centra en la recuperación. Sus componentes fundamentales incluyen:

- **Sistemas de Backup:** La realización periódica de copias de seguridad en soportes externos o en la nube, siguiendo políticas de rotación adecuadas.
- **Redundancia de Hardware:** El uso de sistemas de discos RAID o servidores en clúster que permiten que el sistema siga operando aunque un componente físico falle.
- **Planes de Recuperación ante Desastres (DRP):** Documentos y procedimientos que detallan los pasos exactos a seguir tras un desastre (incendio, ciberataque masivo, inundación) para recuperar la operatividad.
- **Análisis Forense:** El estudio posterior al incidente para identificar la causa raíz, el alcance del daño y evitar que la vulnerabilidad sea explotada nuevamente.



6.3. Sinergia entre Modelos

Un trabajo de investigación integral debe concluir que ambas dimensiones son interdependientes. La seguridad activa es vital para reducir la frecuencia de los incidentes, pero sin una seguridad pasiva sólida, una organización es extremadamente frágil ante lo inevitable. La combinación de ambas permite alcanzar la resiliencia cibernética, asegurando que el sistema no solo resista los ataques, sino que sepa recuperarse con integridad de aquellos que logran traspasar sus defensas.

7. Medidas de Seguridad

7.1. Prevención

Las medidas de prevención constituyen la primera línea de defensa y su objetivo es reducir la probabilidad de que una amenaza explote una vulnerabilidad existente. Estas acciones se ejecutan de manera constante y proactiva.

En el ámbito técnico, la prevención incluye el endurecimiento de sistemas (*hardening*), la gestión de parches para cerrar brechas de seguridad conocidas y la implementación de políticas de control de acceso basadas en el principio de mínimo privilegio. Asimismo, la formación y concienciación de los usuarios se considera una medida preventiva crítica, ya que busca evitar que el factor humano facilite el acceso a atacantes mediante técnicas de ingeniería social.

7.2. Detección

Dado que es imposible garantizar una prevención del 100%, las medidas de detección son esenciales para identificar actividades anómalas o intentos de intrusión en el momento en que ocurren. Estas medidas permiten visibilizar ataques que han logrado eludir las barreras preventivas.

La detección se apoya en herramientas de monitorización continua como los SIEM (*Security Information and Event Management*), que centralizan y analizan los logs de toda la infraestructura. El uso de sistemas de detección de intrusos (IDS) y el análisis de comportamiento mediante inteligencia artificial permiten generar alertas tempranas ante patrones de tráfico inusuales o accesos fuera de horario, activando así los protocolos de respuesta inmediata.

7.3. Restauración

Una vez que un incidente ha comprometido la operatividad o la integridad de los datos, entran en juego las medidas de restauración. El objetivo primordial de esta fase es recuperar la funcionalidad del sistema y devolver los activos de información a su estado original (o a un estado conocido y seguro).

Este proceso se sustenta en la política de copias de seguridad (backups), la cual debe cumplir con criterios de integridad y disponibilidad fuera de línea para evitar que el propio malware afecte a los respaldos. La restauración no se limita a "copiar archivos", sino que implica el levantamiento de servicios siguiendo un orden de prioridad definido en el Plan de Continuidad del Negocio (BCP).

7.4. Análisis Forense

El análisis forense es la fase de investigación técnica que se realiza tras el cierre del incidente. Su propósito es reconstruir la cronología de los hechos, identificar el vector de entrada utilizado por el atacante, determinar el alcance real de la brecha (qué datos fueron comprometidos) y preservar las evidencias digitales.

Este proceso requiere una metodología rigurosa para mantener la cadena de custodia, asegurando que las pruebas no sean alteradas y puedan tener validez legal si fuera necesario. Los resultados del análisis forense son fundamentales para la mejora continua: permiten retroalimentar la fase de prevención, ajustando los controles para asegurar que la misma vulnerabilidad no pueda ser explotada en el futuro.



8. Clasificación de las Amenazas

Las amenazas se agrupan en tres categorías principales que corresponden a las capas del sistema informático analizadas anteriormente.

8.1. Amenazas Físicas

Las amenazas físicas son aquellas que pueden causar daños materiales a la infraestructura, el hardware o los soportes de datos. Estas amenazas suelen tener un impacto directo en la disponibilidad del sistema.

- **Desastres Naturales:** Incendios, inundaciones, terremotos o tormentas eléctricas que pueden destruir físicamente los centros de procesamiento de datos.
- **Fallos de Suministro:** Cortes de energía prolongados o picos de tensión que dañan los componentes electrónicos.
- **Acciones Hostiles Físicas:** Robo de equipos (laptops, servidores, discos duros), sabotaje de las instalaciones o el acceso no autorizado de personas a áreas restringidas para manipular el hardware.

8.2. Amenazas Lógicas

Las amenazas lógicas son aquellas que utilizan software, protocolos de red o debilidades en el código para atacar el sistema desde el interior del entorno digital. Estas amenazas pueden comprometer cualquier pilar de la tríada de seguridad.

- ### 8.3. Amenazas Humanas

- **Amenazas Involuntarias (Errores y Negligencia):** El personal de la organización puede causar daños significativos sin intención maliciosa, como el borrado accidental de bases de datos, la pérdida de dispositivos móviles con información sensible o la configuración incorrecta de un cortafuegos.
- **Amenazas Intencionadas (Ataques dirigidos):** Usuarios Internos (Insiders): Empleados o ex-empleados descontentos que utilizan sus privilegios legítimos para robar propiedad intelectual o sabotear sistemas.
- **Ingeniería Social:** Técnicas de manipulación psicológica, como el *phishing* (correos falsos) o el *pretexting*, diseñadas para que los usuarios revelen voluntariamente sus credenciales de acceso o instalen malware.



9. Factores de Autenticación

9.1. Factor de Inherencia (“Eres”)

Considerado el factor más complejo y difícil de falsificar, se basa en características biométricas físicas o conductuales únicas del individuo. Es el factor que vincula de manera más estrecha la identidad digital con la identidad física.

- **Ejemplos:** Escaneo de huella dactilar, reconocimiento facial, reconocimiento de iris o retina, e incluso patrones de voz o la dinámica de tecleo.
- **Riesgos:** A diferencia de una contraseña, los datos biométricos no se pueden cambiar si se filtran. Además, la precisión del sistema puede verse afectada por falsos positivos (permitir el acceso a un atacante) o falsos negativos (bloquear al usuario legítimo por cambios físicos).



9.2. Factor de Conocimiento (“Conoces”)

Este factor se basa en información que el usuario ha memorizado y que, teóricamente, solo él posee. Es el método más extendido debido a su bajo coste de implementación, pero también es el más vulnerable frente a ataques de ingeniería social o fuerza bruta.



- **Ejemplos:** Contraseñas (passwords), números de identificación personal (PIN), patrones de desbloqueo o las respuestas a preguntas de seguridad predefinidas.
- **Riesgos:** La tendencia de los usuarios a utilizar información predecible (fechas de nacimiento, secuencias simples) o a reutilizar la misma clave en múltiples servicios compromete severamente este factor.

9.3. Factor de Posesión (“Tienes”)

Este nivel de seguridad requiere que el usuario posea un objeto físico o digital específico para validar su identidad. A diferencia del conocimiento, este factor es tangible o depende de un dispositivo hardware.

- **Ejemplos:** Tarjetas inteligentes (smart cards), tokens de seguridad hardware (como llaves YubiKey), generadores de códigos de un solo uso (OTP) enviados vía SMS o aplicaciones de autenticación (Google



Authenticator), y certificados digitales almacenados en un dispositivo.

- **Riesgos:** El principal riesgo es el robo, la pérdida física del objeto o el duplicado de tarjetas SIM (SIM swapping), lo que permitiría a un atacante suplantar la identidad del propietario.

10. Mecanismos de Seguridad

10.1. Medidas de acceso físico

La seguridad física representa la primera barrera de protección y se orienta a salvaguardar el hardware y las instalaciones donde reside la información. Estas medidas buscan mitigar riesgos como el robo, el sabotaje o los daños por catástrofes. Entre los mecanismos más comunes se encuentran el uso de barreras perimetrales, sistemas de videovigilancia (CCTV), controles biométricos para el acceso a salas de servidores (CPD), blindaje de infraestructuras y sistemas de control ambiental para la prevención de incendios o inundaciones.

10.2. Medidas de acceso lógico: contraseñas, etc...

El acceso lógico constituye el conjunto de protocolos de software destinados a verificar la identidad de los usuarios y procesos antes de concederles entrada a los recursos digitales.

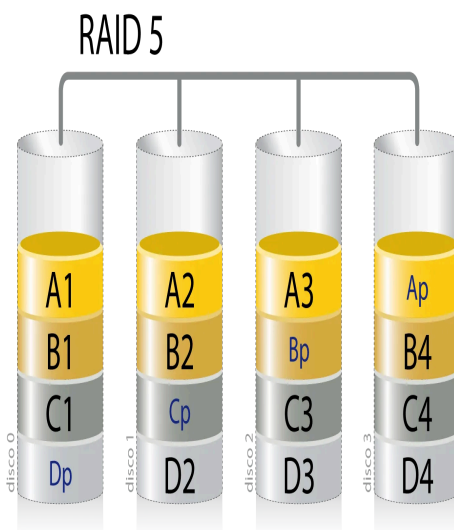


- **Contraseñas:** Es el método de autenticación básico. Su eficacia depende de políticas de complejidad (uso de caracteres alfanuméricos), rotación periódica y el almacenamiento mediante algoritmos de hash seguro.
- **Otros mecanismos:** Incluyen la autenticación de doble factor (2FA), el uso de certificados digitales, tokens de seguridad y sistemas de control de acceso basados en roles (RBAC), que aseguran que cada usuario acceda únicamente a lo autorizado.

10.5. Almacenamiento seguro: RAID, almacenamiento compartido, NAS, nube, etc...

El almacenamiento seguro combina hardware y arquitectura de red para maximizar la disponibilidad y la integridad de los depósitos de datos.

- **RAID:** Configuración de múltiples unidades de disco que funcionan como un solo volumen lógico, proporcionando tolerancia a fallos mediante la distribución de datos y paridad.
- **Almacenamiento compartido y NAS:** Uso de dispositivos conectados a la red (*Network Attached Storage*) que centralizan los archivos, facilitando la gestión de permisos y la administración de cuotas de almacenamiento.
- **Almacenamiento en la nube:** Delegación del almacenamiento a infraestructuras externas de alta disponibilidad que ofrecen redundancia geográfica y protección contra desastres locales.



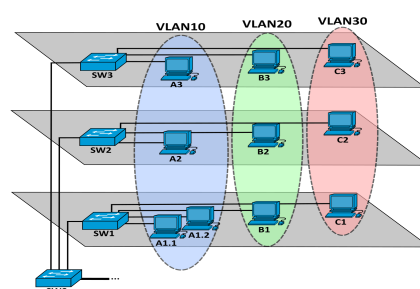
10.6. Restauración: herramientas de rescate del sistema



Los mecanismos de restauración representan la capacidad de respuesta post-incidente. Se basan en el uso de utilitarios de bajo nivel que operan de forma independiente al sistema operativo principal. Estas herramientas permiten el acceso a unidades dañadas para la recuperación de archivos, la reparación del sector de arranque (MBR/GPT) y la limpieza de infecciones persistentes mediante entornos de ejecución pre-instalación (Live OS). Su objetivo es minimizar el tiempo de inactividad (*downtime*) y asegurar el retorno a la operatividad tras un fallo lógico crítico.

10.7. Configuración y arquitectura de red

La arquitectura de red define el mapa lógico y físico por donde circulan los datos. Una configuración segura se fundamenta en la segmentación, que consiste en dividir la red en subredes independientes (VLANs) para evitar que un atacante que acceda a un punto de la red pueda desplazarse lateralmente hacia áreas sensibles. El diseño bajo el modelo de "Confianza Cero" (*Zero Trust*) asegura que



cada segmento de red requiera validación propia, limitando la visibilidad de los activos internos desde el exterior.

10.8. Encriptación, protocolos seguros y certificados

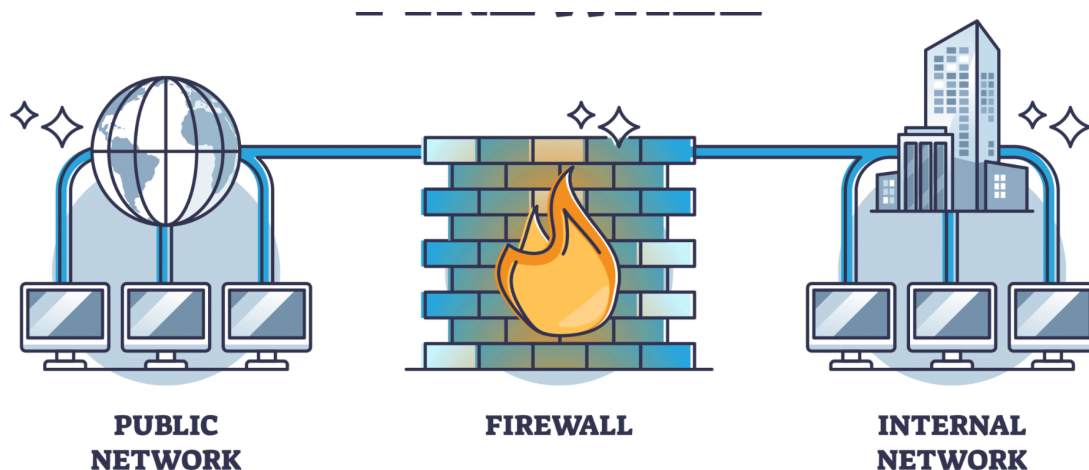
Esta capa de protección garantiza la tríada de seguridad en el intercambio de información.



- **Encriptación:** Aplicación de algoritmos para asegurar que solo los extremos con la clave legítima puedan interpretar la información.
- **Protocolos seguros:** Implementación de estándares de comunicación que incluyen seguridad nativa, como HTTPS, SSH, SFTP o TLS, sustituyendo a sus versiones vulnerables (HTTP, Telnet, FTP).
- **Certificados:** Documentos digitales emitidos por Autoridades de Certificación (CA) que vinculan una clave pública con una entidad, garantizando la autenticidad del sitio o servicio y evitando ataques de suplantación.

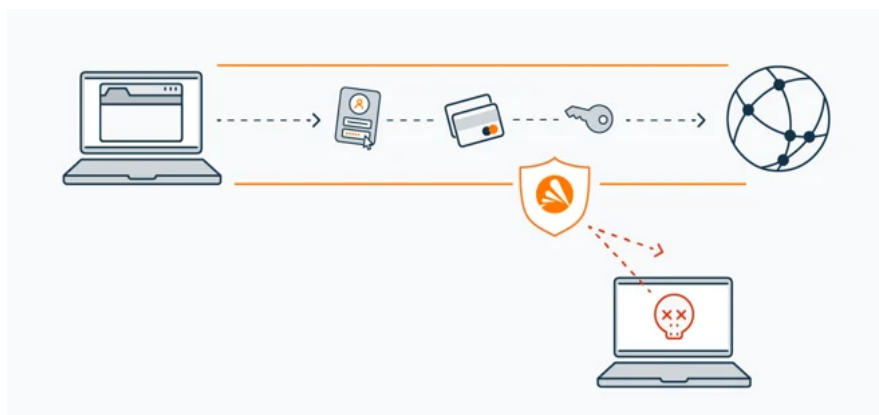
10.9. Cortafuegos (Firewall)

El cortafuegos actúa como el guardián perimetral del sistema. Su función es filtrar el tráfico de red entrante y saliente basándose en un conjunto de reglas de seguridad predefinidas. Puede operar a nivel de red (filtrando por direcciones IP y puertos) o a nivel de aplicación (inspeccionando el contenido de los paquetes). Es la herramienta principal para bloquear intentos de intrusión y denegar accesos desde orígenes geográficos o direcciones sospechosas, aislando la red interna de las amenazas de la red pública.



10.10. Monitorización y análisis de red

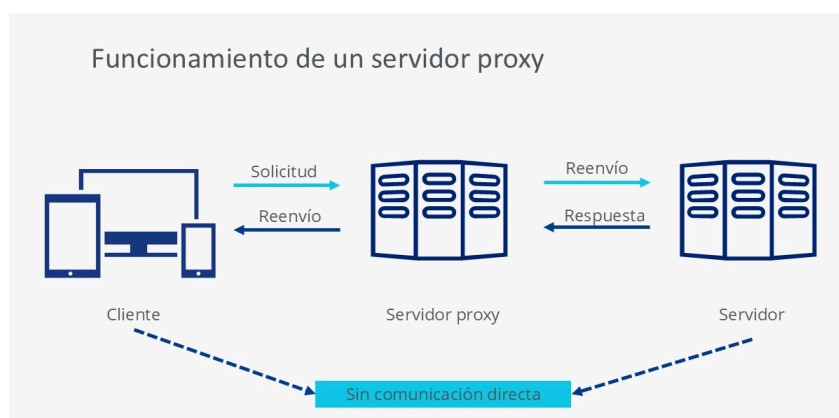
La monitorización es el proceso de vigilancia continua de los flujos de datos para identificar anomalías. Mediante el uso de herramientas de análisis de paquetes (*Sniffers*) y sistemas de gestión de eventos (SIEM), se pueden detectar patrones que indiquen un ataque en curso, como escaneos de puertos o picos de tráfico inusuales. El análisis de red no solo sirve para la defensa en tiempo real, sino que proporciona los datos necesarios para realizar diagnósticos de rendimiento y auditorías de seguridad preventivas.



10.11. Acceso privado: proxy, vpn

Estos mecanismos extienden o protegen el perímetro de la red para usuarios que operan fuera de la infraestructura local o para controlar la navegación interna.

- **Proxy:** Actúa como un intermediario entre el cliente y el servidor. Se utiliza para ocultar la identidad de los equipos internos, filtrar contenido web no deseado y acelerar el acceso a recursos mediante el almacenamiento en caché.
- **VPN (Red Privada Virtual):** Crea un túnel cifrado de comunicación sobre una infraestructura pública como Internet. Permite que usuarios remotos accedan a los recursos de la red corporativa con el mismo nivel de seguridad y cifrado que si estuvieran físicamente conectados a la red local.



11. Criptografía

11.1. Definición

La criptografía se define como la ciencia y el arte de escribir mensajes en clave o de forma enigmática. En el contexto de la seguridad informática, es la disciplina que utiliza modelos matemáticos para transformar un mensaje legible (texto plano) en uno ininteligible (criptograma), garantizando que solo los poseedores de una clave específica puedan revertir el proceso. Su propósito trasciende la ocultación, abarcando pilares fundamentales como la confidencialidad, la integridad de los datos y la autenticación de las partes.



11.2. Usos

En la actualidad, la criptografía es el componente invisible que permite la confianza en los sistemas digitales. Sus aplicaciones principales incluyen:

- **Seguridad en las comunicaciones:** Protocolos que protegen el intercambio de mensajes en tiempo real y correos electrónicos.
- **Transacciones financieras:** El uso de SSL/TLS para cifrar datos bancarios durante compras en línea.
- **Identidad digital:** El empleo de firmas electrónicas para validar documentos legales sin presencia física.
- **Protección de activos:** El almacenamiento de contraseñas mediante funciones hash y la seguridad de las carteras de criptomonedas basadas en *blockchain*.

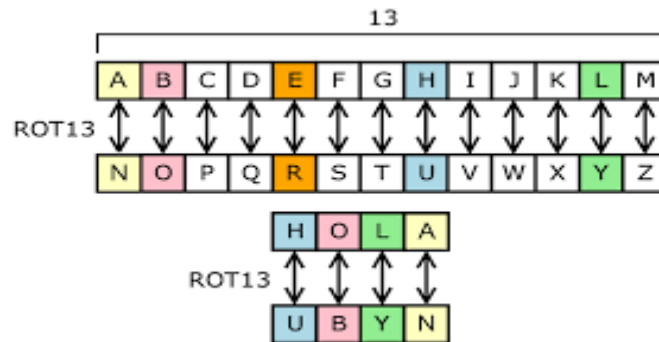
11.3. Cifrados antiguos: Escítala, César, Blaise de Vigenere, Enigma, etc.

La evolución de la criptografía muestra la transición de métodos mecánicos simples a sistemas de alta complejidad algorítmica:

- **Escítala (Esparta, S. V a.C.):** Considerado un cifrado de transposición. Consistía en una tira de cuero enrollada sobre un bastón (escítala). El mensaje solo era legible si se disponía de un bastón del mismo diámetro, lo que reorganizaba las letras para formar palabras coherentes.
- **Cifrado César (Roma, S. I a.C.):** Un método de sustitución monoalfabética. Cada letra del texto original se sustituía por otra que se encontraba un número fijo de posiciones más adelante en el alfabeto (comúnmente un desplazamiento de 3).
- **Blaise de Vigenère (S. XVI):** Introdujo la sustitución polialfabética, utilizando una palabra clave para variar el desplazamiento en cada letra del mensaje. Este

sistema rompió con el análisis de frecuencias simple, siendo denominado durante siglos como *le chiffre indéchiffrable*.

- **Máquina Enigma (S. XX):** Un dispositivo electromecánico de rotores utilizado durante la Segunda Guerra Mundial. Su seguridad radicaba en la enorme cantidad de configuraciones posibles, que cambiaban tras cada pulsación, obligando al desarrollo de la computación temprana para su ruptura.



11.4. Tipos de cifrado

11.4.1. Simétrico (DES, 3DES, AES, RC5, Blowfish, IDEA, ...)

El cifrado simétrico, también conocido como de clave privada, se caracteriza por utilizar una única clave para los procesos de cifrado y descifrado. Su principal ventaja es la alta velocidad de procesamiento, lo que lo hace ideal para cifrar grandes volúmenes de datos.

- **DES y 3DES:** Estándares antiguos; el primero hoy considerado vulnerable y el segundo una evolución que aplica el algoritmo tres veces para aumentar la seguridad.
- **AES:** El estándar global actual, altamente seguro y eficiente.
- **Blowfish e IDEA:** Alternativas diseñadas para ofrecer robustez sin las limitaciones de patentes de otros algoritmos.



11.4.2. Asimétrico (DSA, RSA, Diffie-Hellman, ...)

Este tipo de cifrado utiliza un par de claves matemáticamente relacionadas: una clave pública para cifrar y una clave privada para descifrar. Resuelve el problema de la distribución de claves de los sistemas simétricos.

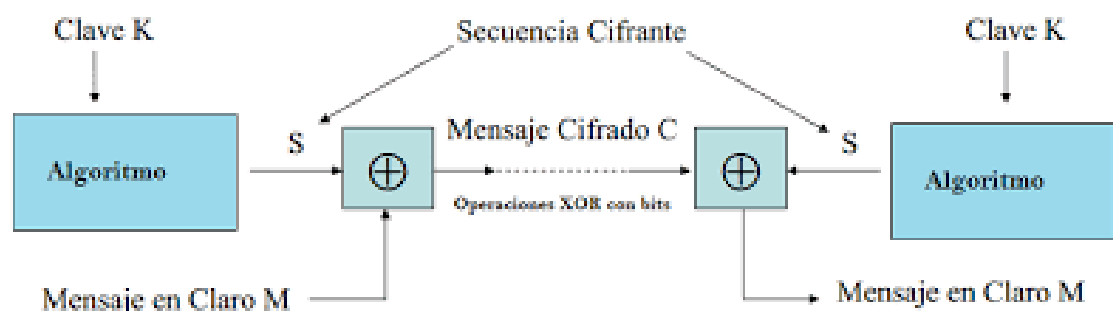
- **RSA:** El algoritmo más utilizado para la firma digital y el cifrado de datos sensibles.
- **Diffie-Hellman:** Un protocolo fundamental que permite a dos partes generar una clave compartida a través de un canal inseguro.
- **DSA:** Estándar específico para la generación de firmas digitales, asegurando la autenticidad pero no el cifrado de datos en sí.



11.4.3. Cifradores de flujo (WEP, WPA)

A diferencia de los cifradores de bloque, los de flujo cifran los datos bit a bit o byte a byte en tiempo real. Son comunes en las comunicaciones inalámbricas donde la velocidad y la continuidad son críticas.

- **WEP:** Protocolo original para redes Wi-Fi, actualmente considerado totalmente inseguro debido a debilidades en su implementación del cifrado de flujo.
- **WPA (y sus sucesores WPA2/WPA3):** Evoluciones que introdujeron protocolos de integridad de clave temporal (TKIP) y AES para corregir las vulnerabilidades de los flujos de datos inalámbricos.



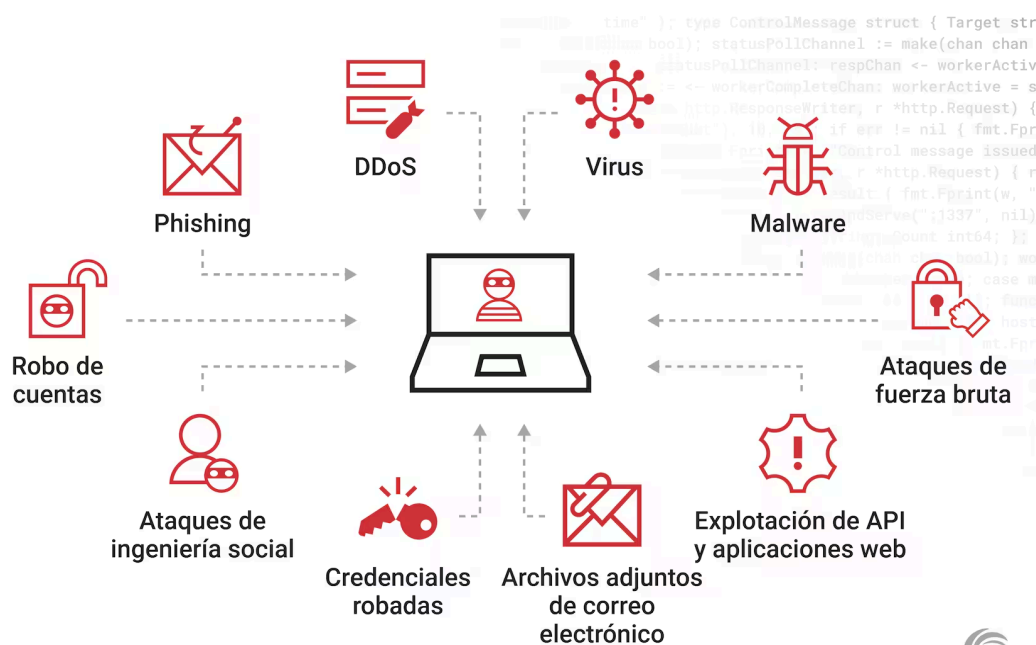
11.6. Ataques

En el ámbito de la criptografía, los ataques no siempre buscan "adivinar" la clave, sino encontrar debilidades en el algoritmo, en su implementación o en el comportamiento humano.

11.6.1. Clave (fuerza bruta, diccionario, ingeniería social, keyloggers, ...)

Este grupo de ataques no busca vulnerar el algoritmo matemático, sino obtener el "secreto" (la contraseña o clave) que permite el acceso legítimo al sistema.

- **Fuerza Bruta:** Método exhaustivo que consiste en probar todas las combinaciones posibles de caracteres hasta hallar la clave correcta. Su éxito es directamente proporcional a la capacidad de cómputo e inversamente proporcional a la longitud y complejidad de la contraseña.
- **Diccionario:** Variante optimizada de la fuerza bruta que utiliza listas de palabras predefinidas, términos comunes, nombres propios y contraseñas filtradas en brechas previas para reducir el tiempo de búsqueda.
- **Ingeniería Social:** Técnica de manipulación psicológica que busca que el usuario revele voluntariamente su clave. Se basa en el engaño (phishing, pretexting) aprovechando el exceso de confianza o el desconocimiento del factor humano.
- **Keyloggers:** Software o hardware malicioso diseñado para registrar cada pulsación de tecla realizada por el usuario. Es un ataque altamente efectivo para capturar credenciales en el momento exacto en que son introducidas, evadiendo incluso el cifrado de la interfaz.



11.6.2. Cifrado (estadística, criptoanálisis)

A diferencia de los ataques a la clave, estos se centran en encontrar debilidades en el propio sistema de cifrado o en la forma en que se ha implementado el mensaje.

- **Estadística (Análisis de frecuencias):** Se basa en el estudio de la frecuencia con la que aparecen ciertas letras o patrones en un idioma específico. En cifrados de sustitución simples, si una letra aparece con una frecuencia similar a la de la "E" en español, el atacante puede deducir la equivalencia, permitiendo descifrar el mensaje sin conocer la clave.
- **Criptoanálisis:** Es el estudio matemático de los algoritmos de cifrado con el fin de encontrar vulnerabilidades lógicas. El criptoanálisis busca reducir la complejidad del algoritmo para que sea posible descifrarlo en un tiempo menor al que requeriría la fuerza bruta. Esto puede incluir el aprovechamiento de errores en la generación de números aleatorios o debilidades en la estructura del código criptográfico.

12. Ingeniería Social

12.1. Definición y Principios Fundamentales

La ingeniería social es el conjunto de técnicas que buscan engañar a las personas para que divulguen información sensible, realicen acciones que comprometan la seguridad o permitan el acceso a áreas restringidas. Se basa en seis principios de influencia psicológica: autoridad, urgencia, escasez, confianza, reciprocidad y validación social.

12.2. Fases de un Ataque de Ingeniería Social

Un ataque estructurado de ingeniería social suele seguir un ciclo de vida definido:

- **Recolección de información:** El atacante investiga a la víctima (redes sociales, estructura de la empresa).
- **Establecimiento de relación:** Se crea un pretexto para ganar la confianza del objetivo.
- **Explotación:** Se solicita la acción deseada (hacer clic en un enlace, revelar una clave).
- **Ejecución y Retirada:** El atacante obtiene lo que busca y desaparece sin levantar sospechas.

12.3. Técnicas Comunes de Ingeniería Social

- **Phishing:** Es la técnica más extendida. Consiste en el envío de correos electrónicos fraudulentos que suplantan a entidades legítimas (bancos,

servicios técnicos) para robar credenciales o instalar malware. Existen variantes como el Smishing (vía SMS) y el Vishing (vía llamadas telefónicas).

- **Pretexting:** El atacante crea un escenario ficticio elaborado (el "pretexto") donde suele hacerse pasar por un técnico de soporte, un auditor o un directivo de la empresa para solicitar datos que, en teoría, necesita para resolver un problema urgente.
- **Baiting (Cebo):** Consiste en dejar un dispositivo físico infectado (como una memoria USB) en un lugar público con una etiqueta atractiva (ej. "Salarios 2026"). La curiosidad lleva a la víctima a conectarlo a su equipo, ejecutando el malware de forma automática.
- **Tailgating / Piggybacking:** Esta técnica ocurre en el plano físico. El atacante sigue a una persona autorizada para entrar en una zona restringida aprovechando que la puerta queda abierta, a menudo cargando objetos pesados para forzar la amabilidad del empleado y que este le sujete la puerta.
- **Quid pro quo:** El atacante ofrece un servicio o beneficio a cambio de información. Un ejemplo común es llamar a empleados al azar fingiendo ser del servicio de asistencia técnica y ofrecer una "mejora de red" que requiere que el usuario proporcione su contraseña.



12.4. Medidas de Mitigación

La defensa contra la ingeniería social no es puramente tecnológica, sino educativa. Las organizaciones deben implementar:

- **Programas de concienciación:** Capacitación periódica para que los empleados identifiquen intentos de manipulación.
- **Protocolos de verificación:** Normas estrictas que impidan la entrega de información sensible por teléfono o correo sin una doble validación.
- **Cultura de seguridad:** Fomentar un entorno donde los empleados se sientan cómodos reportando anomalías sin temor a represalias.

13. Normativa de Seguridad

13.1. Ámbito Europeo (Unión Europea)

La Unión Europea ha liderado la creación de un ecosistema digital seguro y privado, estableciendo normas que son de obligado cumplimiento para todos los estados miembros.

- **RGPD (Reglamento General de Protección de Datos):** Es la normativa más relevante en materia de privacidad. Regula cómo las organizaciones deben recoger, tratar y proteger los datos personales de los ciudadanos europeos, imponiendo sanciones severas en caso de brechas de seguridad o negligencia.
- **Directiva NIS 2:** Establece un elevado nivel común de ciberseguridad en toda la Unión. Se enfoca en la protección de sectores críticos (energía, salud, banca, infraestructuras digitales) y obliga a las empresas estratégicas a implementar medidas de gestión de riesgos y notificar incidentes graves.

13.2. Ámbito Nacional (España)

España posee una de las legislaciones más avanzadas en materia de ciberseguridad, adaptando las directrices europeas a su marco jurídico interno.

- **ENS (Esquema Nacional de Seguridad):** Regulado por el Real Decreto 311/2022, es de aplicación obligatoria para el Sector Público y sus proveedores tecnológicos. Establece los principios básicos y requisitos mínimos para garantizar la seguridad de la información procesada en sus sistemas.
- **LOPDGDD (Ley Orgánica de Protección de Datos y Garantía de los Derechos Digitales):** Adapta el RGPD al derecho español y añade derechos digitales para los ciudadanos, como el derecho al olvido o a la desconexión digital en el ámbito laboral.
- **Ley de Infraestructuras Críticas (Ley LPIC):** Destinada a proteger las instalaciones estratégicas cuyo funcionamiento es indispensable (hospitales, centrales nucleares, redes de agua) frente a ataques físicos o lógicos.

13.3. Certificaciones y Estándares Internacionales

Más allá de las leyes, existen marcos de trabajo voluntarios que permiten a las organizaciones certificar su madurez en seguridad ante terceros.

- **ISO/IEC 27001:** Es el estándar internacional por excelencia para la implantación de un SGSI (Sistema de Gestión de Seguridad de la información). Proporciona una metodología basada en la mejora continua y el análisis de riesgos.

- **ISO/IEC 27002:** Guía de buenas prácticas que detalla los controles específicos (físicos, organizativos y técnicos) que pueden implementarse para cumplir con los objetivos de la 27001.
- **Certificaciones Profesionales:** Estándares como CISA, CISM o CISSP validan los conocimientos de los especialistas encargados de auditar y gestionar la seguridad a nivel global.

13.4. Ética y Responsabilidad Legal

La normativa no solo protege a los datos, sino que define la responsabilidad de los profesionales. En España, el Código Penal tipifica delitos informáticos como el acceso no autorizado (hacking), la interceptación de comunicaciones, el daño informático (sabotaje) y la estafa electrónica. El cumplimiento normativo (*compliance*) es hoy una pieza clave para evitar la responsabilidad penal de las personas jurídicas.

Bibliografía

PUNTO 1: SEGURIDAD

1. Wikipedia, la enciclopedia libre. (2024, 15 de marzo). Seguridad informática. Consulta: https://es.wikipedia.org/wiki/Seguridad_informática
2. Wikipedia, la enciclopedia libre. (2024, 2 de febrero). Tríada de la CIA. Consulta: https://es.wikipedia.org/wiki/Seguridad_de_la_información

PUNTO 2: SISTEMA INFORMÁTICO

1. Wikipedia, la enciclopedia libre. (2023, 26 de agosto). Sistema informático. Consulta: https://es.wikipedia.org/wiki/Sistema_informático
2. Wikipedia, la enciclopedia libre. (2023, 23 de agosto). Hardware. Consulta: <https://es.wikipedia.org/wiki/Hardware>
3. Wikipedia, la enciclopedia libre. (2023, 13 de julio). Software de sistema. Consulta: https://es.wikipedia.org/wiki/Software_de_sistema

PUNTO 3: SISTEMA SEGURO VS FIABLE

1. IBM Documentation: Reliable vs. Secure systems. Consulta: <https://www.ibm.com/docs/es/sdk-java-technology/8?topic=guide-security-reliability>
2. INCIBE (Instituto Nacional de Ciberseguridad): Glosario de términos. Consulta: <https://www.incibe.es/pyme/glosario>

PUNTO 4: CARACTERÍSTICAS DE UN SISTEMA SEGURO

1. ISO/IEC 27001: Information Security Management Systems. Consulta: <https://www.iso.org/standard/27001>
2. Microsoft Learn: Introducción a la seguridad de la información. Consulta: <https://learn.microsoft.com/es-es/training/modules/describe-security-concepts-methodologies/>

PUNTO 5 Y 8: AMENAZAS Y CATEGORÍAS DE ATAQUE

1. OWASP Top Ten Project: Clasificación de ataques. Consulta: <https://owasp.org/www-project-top-ten/>
2. Wikipedia, la enciclopedia libre: Amenaza informática. Consulta: https://es.wikipedia.org/wiki/Amenaza_informática

PUNTO 6, 7 Y 10: MECANISMOS Y MEDIDAS DE SEGURIDAD

1. Cisco: ¿Qué es un firewall? / Seguridad de red. Consulta: https://www.cisco.com/c/es_mx/products/security/firewalls/what-is-a-firewall.html Microsoft Learn: Copias de seguridad y restauración. Consulta:

<https://learn.microsoft.com/es-es/windows-server/storage/storage-spaces/deploy-standalone-storage-spaces>

2. Wikipedia: RAID y almacenamiento. Consulta:
<https://es.wikipedia.org/wiki/RAID>

PUNTO 11: CRIPTOGRAFÍA

1. Wikipedia, la enciclopedia libre: Criptografía. Consulta:
<https://es.wikipedia.org/wiki/Criptografía>
2. RSA Security: Conceptos de cifrado asimétrico. Consulta:
<https://www.rsa.com/exchange/white-paper/asymmetric-cryptography/>

PUNTO 12 Y 13: INGENIERÍA SOCIAL Y NORMATIVA

1. Agencia Española de Protección de Datos (AEPD): Guía del RGPD. Consulta:
<https://www.aepd.es/es/guia-rgpd>
2. INCIBE: Ingeniería Social, qué es y cómo protegerse. Consulta:
<https://www.incibe.es/ciudadania/temas/ingenieria-social>